MERIDIAN HEALTH NETWORK

Building a Complete Incident Response Program

Incident Response Assessment

A scenario-based assessment of suspected ransomware or file encryption, phishing, and suspicious account activity, including severity, incident leadership, RACI responsibilities, communications, and potential HIPAA breach-notification considerations.

Assessment focus

- Incident identification and severity triage
- Roles and responsibilities using RACI
- First 30–60 minute communications
- Containment, evidence preservation, and recovery
- Conditional regulatory notification assessment

Case study: 12 clinics, one data center, and cloud-hosted patient records

1. Executive Summary

Meridian Health Network operates 12 clinics and a data center, uses Azure-hosted patient records, supports a patient portal and telehealth platform, relies on a third-party billing and claims vendor, and provides clinicians with VPN access. The scenario describes three concurrent warning signs: encrypted file shares at two clinics, a phishing email impersonating IT Support, and unusual after-hours logins from a former contractor account. Meridian has no formal incident response plan, clear response roles, or tested playbooks.

The situation should be treated as a **high-priority suspected security incident with potential ransomware activity and possible unauthorized account use**. The available facts do not prove that patient data was exfiltrated or that a reportable HIPAA breach occurred. The response team should rapidly validate scope, contain threats, preserve evidence, maintain patient-care continuity, and involve Privacy/Legal leadership in a documented breach-risk assessment.

Immediate priority: appoint an Incident Commander, activate the response team, isolate affected systems where safe, disable or suspend the former contractor account, preserve logs and relevant evidence, and establish one verified communication channel. Do not power off or rebuild systems without coordinating with incident responders, because doing so may destroy evidence or complicate recovery.

2. Incident Assessment and Severity

Severity should reflect confirmed impact, scope, threat activity, and patient-care risk. The labels below are proposed operational classifications for this scenario; Meridian should formally define its severity criteria in its incident response plan.

Signal / incident	Proposed severity	Assessment and rationale	Initial response
Encrypted file shares at two clinics	**SEV 1 / Critical, pending validation**	May indicate ransomware or malicious encryption affecting multiple clinical locations. Availability of clinical records and patient-care operations may be at risk. Confirm whether encryption is unauthorized and determine scope.	Escalate immediately; isolate affected segments/systems as appropriate; protect backups; preserve endpoint, server, and identity logs; coordinate clinical continuity.
Phishing email impersonating IT Support	**SEV 2 initially; escalate if compromise is confirmed**	A phishing attempt alone does not prove compromise. Severity rises if users clicked, submitted credentials, opened a malicious attachment, or the email is linked to observed activity.	Alert users; preserve the email and headers; block indicators where safe; search for related messages; reset credentials or revoke sessions if compromise is suspected.
After-hours logins from former contractor account	**SEV 1 / High priority**	A former contractor account may remain active and could be compromised or misused. The login is suspicious, but the facts do not by themselves confirm data theft or a breach.	Disable or suspend the account; revoke sessions and tokens; review authentication, VPN, and access logs; identify accessed systems and data; preserve evidence.
No formal IR plan / single responder	**Program-level critical weakness**	This is a readiness and governance gap rather than a separate technical incident. It can delay containment, fragment decisions, and overload one responder.	Appoint an Incident Commander and deputies; activate named technical, legal/privacy, communications, and clinical leaders; use a common incident log.

Severity note

The encrypted file shares are the strongest indicator of a potentially severe incident because they may disrupt clinical operations at two locations. Treat the overall event as SEV 1 until initial triage establishes that impact is limited. The phishing message and contractor login may be related, but responders must validate that relationship rather than assume it.

3. Roles and Responsibilities: RACI

RACI means Responsible (does the work), Accountable (owns the outcome and makes the final decision), Consulted (provides input), and Informed (kept updated). Each activity should have one clearly identified accountable role wherever practicable.

Activity	Incident Commander	IT / Network Lead	Legal & Compliance	Comms Lead	Business / Clinical Leadership
Declare incident and set severity	**A**	R	C	I	I
Investigate, contain, preserve evidence	A	**R**	C	I	C
Assess privacy impact and notification duties	A	C	**R**	C	C

Activity	Incident Commander	IT / Network Lead	Legal & Compliance	Comms Lead	Business / Clinical Leadership
Coordinate internal updates	A	C	C	**R**	I
Maintain clinical continuity and business decisions	A	R	C	I	**R**
Authorize recovery and close incident	**A**	R	C	I	C

Role clarifications

The Incident Commander coordinates the response and makes incident-level decisions within delegated authority. IT/Security leads technical investigation and containment. Legal & Compliance coordinates privacy and regulatory analysis, not technical containment. The Communications Lead prepares consistent updates approved by the Incident Commander and Legal/Privacy as appropriate. Clinical leadership directs patient-care continuity decisions.

4. First 30–60 Minutes: Communication and Actions

0–10 minutes — Activate the incident response process; appoint the Incident Commander and incident scribe; open an incident record; contact IT/Security, Privacy/Legal, and clinical leadership through an approved channel.

10–20 minutes — Confirm affected clinics, systems, and services. Isolate affected devices or network segments when safe and appropriate. Disable the former contractor account, revoke active sessions, and preserve identity/VPN logs. Do not delete the phishing email or wipe affected systems.

20–30 minutes — Notify the executive sponsor and relevant operational leaders. Ask the helpdesk to preserve phishing reports and identify users who clicked or supplied credentials. Confirm whether patient care, EHR access, backups, or critical services are disrupted.

30–60 minutes — Establish a common operating picture: known facts, unknowns, actions, owners, and next update time. Engage the privacy officer and legal counsel to assess possible PHI exposure and applicable notification duties. Prepare a continuity plan for affected clinics.

Internal stakeholders to notify promptly

- Incident Commander / designated incident response lead
- IT/Security and network operations
- Privacy Officer and Legal & Compliance
- Executive sponsor or senior leadership
- Clinical operations leadership for affected clinics
- Communications lead and helpdesk, as needed

Use a single approved incident channel and an incident log. Share information on a need-to-know basis; avoid speculation and do not send sensitive details through an unapproved channel.

5. HIPAA and Breach Notification Considerations

The scenario could trigger HIPAA breach-notification duties, but a notification obligation cannot be determined from the current facts alone. Encrypted files, a phishing email, and suspicious logins are serious indicators that require investigation; they do not automatically prove that unsecured protected health information (PHI) was acquired, accessed, used, or disclosed impermissibly.

Legal/Privacy should lead a documented assessment to determine whether PHI was involved, whether an impermissible use or disclosure occurred, whether an exception applies, and whether the information was rendered unusable, unreadable, or indecipherable to unauthorized persons using a methodology specified by applicable guidance. The organization should follow the applicable HIPAA Breach Notification Rule and any stricter state, contractual, or other legal requirements that apply.

Important correction

A breach notification is not triggered simply because containment was slow or damage became severe. The key question is whether a reportable breach of unsecured PHI occurred under the applicable rule. Do not delay incident containment while waiting for the legal assessment; technical response and privacy assessment should proceed in parallel.

6. Incident Response Lifecycle

Use a documented six-phase lifecycle and record decisions, evidence, and approvals throughout:

Phase	Application to this scenario
1. Preparation	Approve the incident response plan, define roles and escalation criteria, maintain contact lists and playbooks, and test backups and communications.
2. Detection and Analysis	Correlate file encryption, phishing reports, and contractor account activity; establish scope, impact, timeline, and confidence level.
3. Containment	Isolate affected systems and segments; disable compromised accounts and revoke sessions; protect unaffected systems and backups.
4. Eradication	Remove malware or unauthorized access, close exploited pathways, rotate affected credentials, and validate systems before reconnecting.
5. Recovery	Restore from verified clean backups, test system integrity, monitor for reinfection, and confirm clinical services are safe to resume.

Phase	Application to this scenario
6. Post-Incident Activity	Complete root-cause analysis, preserve evidence, document lessons, track corrective actions, assess notification obligations, and update playbooks.

7. Results, Findings, and Improvement Plan

The original submission correctly recognized that phishing, suspicious former-contractor access, and encrypted file shares require escalation. It also correctly identified the lack of an incident response plan and the need to notify IT leadership and an executive sponsor. The following changes improve precision and operational usefulness:

• Separate a confirmed incident from an indicator that needs investigation; a phishing email alone does not establish account compromise.
• Treat encryption affecting two clinics as a potentially critical event until impact is understood.
• Treat the single-responder problem as a program weakness, not a separate technical incident severity.
• Expand RACI across activities so each role has a clear, defensible responsibility.
• Notify Privacy/Legal early and assess notification based on the facts and applicable requirements, not on delayed containment alone.
• Preserve evidence and coordinate technical response with clinical continuity.

Priority improvement actions

1. Approve an incident response policy and plan with severity definitions, escalation thresholds, decision authority, and an incident log template.
2. Create playbooks for ransomware/file encryption, phishing, compromised accounts, third-party incidents, and potential PHI exposure.
3. Test account deprovisioning, MFA, logging, backups, restoration, and network isolation procedures.
4. Run tabletop exercises involving IT/Security, Legal/Privacy, Communications, and clinical leadership.
5. Track remediation actions to closure and review the plan after exercises and real incidents.

8. Conclusion

Meridian should respond to the scenario as a potentially critical security event while validating what has actually occurred. Effective response requires coordinated technical containment, evidence preservation, clear incident leadership, clinical continuity planning, and an evidence-based privacy and regulatory assessment. A tested plan and threat-specific playbooks would reduce confusion and improve the organization's ability to protect patient services and sensitive information.

9. Author

Project: Meridian Health Network Incident Response Assessment
Specialization: Governance, Risk, and Compliance (GRC) / Incident Response
Focus areas: Incident Severity, RACI, Communications, Containment, HIPAA Breach Assessment, Incident Response Lifecycle

---

Educational case study based on the supplied assignment scenario and submitted response. This report is not a legal opinion, certification, or formal audit of an actual organization.